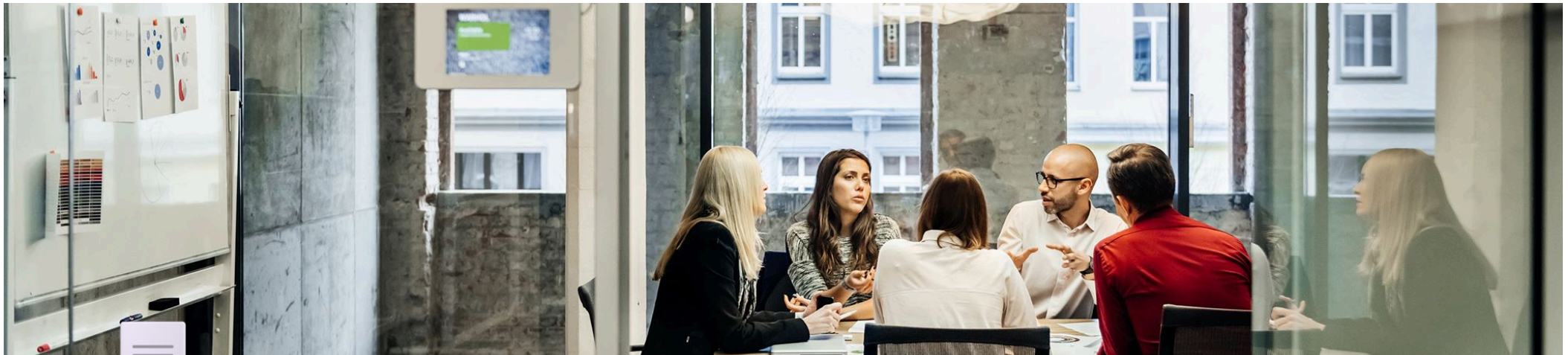




Bistec-ISMS-PR-001 - IS Risk Assessment Procedure



The Risk Assessment and Treatment Procedure helps organizations identify, evaluate, and prioritize information security risks to protect sensitive data. It ensures that appropriate controls are implemented to mitigate or manage these risks, promoting continuous improvement in information security management.

Document Controls

Document Number: Bistec-ISMS-PR-001- Risk Assessment and Treatment Procedure

Classification: Confidential-Internal

Owner: IS Officer

Effective Date: 15-Dec-25

Document History

	≡ Release Date	≡ Revision No	≡ Author	≡ Description	≡ Approved By
1	01-Nov-25	1.0	IS Officer	Initial Release	ISSC
2	18-Feb-26	1.1	IS Officer	Included DPIA Procedure	ISSC

Purpose

This procedure describes the method for identifying, estimating, assessing, and treating risks related to information security of Bistec Global Private Limited (hereafter referred to as “Bistec”).

Distribution

This is an internal document and should only be shared with employees of Bistec and intended parties determined by the IS

Officer.

Scope

The scope and the context of the Bistec Information Security (IS) risk assessment and treatment plan apply for the process areas that cover under the scope of ISMS of Bistec. The procedure covers the process is depicted below.

Definition

	≡ Terms	≡ Definitions
1	Risk	Combination of the probability of an unwanted event and its consequences.
2	Threat	A threat is a potential event. When a threat turns into an actual event, it may cause an unwanted incident. It is unwanted because the incident may harm an organization or system.

Risk Management Framework

This procedure was developed with the consultation of the ISO/IEC 31000:2018 Principles of Risk Management and ISO/IEC 27005:2018 Information Security Risk Management guidelines.

Establishing Context

- The Information Security Committee (ISC) shall decide the context in which the risk assessment will be performed.
- This procedure will be used in conducting the risk assessment.
- Risk assessment and treatment will be carried out for specific process areas mentioned in the scope section.

Risk Assessment Frequency and Triggers

- IS Officer shall initiate the routine risk assessment procedure on an **annual basis**.
- The IS Officer may initiate a non-routine risk assessment based on the trigger events but not limited to the following:
 - Changes to the scope and boundaries of the information security management system.
 - Addition of new services or sectors of operations.
 - Addition of new equipment, servers, and applications.
 - Major changes to application, network, and security architecture.
 - Major change in the process; and
 - Emergence of new threats and/or vulnerabilities.
 - Third-party access to Bistec information, premises or Bistec systems.
- The scope of the non-routine risk assessment shall be specific to cover potential risks that may arise due to the above-mentioned trigger events.
- Acceptance of risks and residual risks shall be performed based on the Risk Acceptance Criteria as given in this procedure.
- The summary of all the annual risk assessments and non-routine risk assessments shall be communicated to ISC.

Risk Identification – Process Identification and Valuation

- The main objective of risk identification is to identify the sources of risk, areas of impacts, events and their causes and their

potential consequences.

- Risk identification will be performed on the identified processes within the scope that support or involve in business operations at Bistec.
 - Processes that affected.
 - Software Services
 - Digital Services
 - Operations
 - Accounting Services
 - Marketing Services
 - IT Services
- Upon identifying the processes, the team shall identify the possible risks that may arise which may have an impact to the confidentiality, integrity, and availability of service delivery. Following techniques can be used to identify potential risks:
 - Brainstorming.
 - Past or historical events.
 - Current risk landscape.
 - Emerging threats/ vulnerabilities; and
 - Questionnaires.
- Bistec shall identify risk owners for each identified risk. A risk owner is a person or entity that has been given the authority to manage a particular risk and is accountable for doing so.

Data Protection Impact Assessment (DPIA) - Data Protection Impact Assessment (DPIA) P...

Risk Analysis – Risk Impact: Analyzing Consequences of a Risk

- Upon identifying the processes within the areas that are in scope for Information Security of Bistec, process owners shall determine the possible risks that may cause a loss or an inadequate performance of process or the service. Process owners shall analyze the consequence of the risk if it was to materialize. The following table can be used in determining the consequence.

	≡ Impact	≡ 1= Insignificant	≡ 2= Moderate	≡ 3 = Major
1	Confidentiality	Contains publicly available information.	Contains information that can be shared with internal employees at Bistec. The information cannot be shared with third parties without approval.	Contains highly sensitive information that can be shared with only a designated individual. Information owner shall explicitly approve if the information to be shared with any party or individual (including third party)

2	Regulatory Compliance	No violation of regulatory compliance.	May lead to a violation of regulatory compliance.	Violation of regulatory compliance.
3	Legal	No compliance breach of legal requirement.	May lead to compliance breach in future	Violation of legal requirement and lead to legal implications.
4	Reputation/Recovery	No adverse customer attention. Not impacting potential businesses. No reputation impact	Customer complaints include negative posts online (e.g., blogs, twitter, etc.). Estimated time to restore reputation: 1 year Attention of customer however will not impact future businesses with customers or any potential businesses.	Widespread negative publicity online (e.g., blogs, twitter, YouTube etc.). Long-lasting reputation damage. Criminal prosecutions. Political intervention. Adverse customer attention. Loss of customers and loss of potential business.

5	Opportunity Cost	Based on the criticality and urgency, seven days of the ISC's sole attention to address.	Based on the criticality and urgency, two days of the ISC's sole attention to address.	Up to one day of (Information Security Committee) ISSC's sole attention to address the issue.
6	Service	No fall in service quality. No breach in customer service agreement obligations.	Moderate fall in service quality provided by Bistec. Downtime of critical IT services up to few hours.	Significant fall in service quality provided by Bistec. Downtime of critical IT services up to 1 day.

Risk Likelihood Analysis

- Realistic likelihood of the risk materializing shall be calculated as per the below table.

	≡ Rating	≡ Rating Guideline
1	1. Unlikely	The event may occur at some time but not likely to occur in the foreseeable future (i.e., once within the next 1 to 2 years)
2	1. Possible	The event may occur within the foreseeable future or medium term (i.e., once every 0.5-1 years)
3	1. Likely	The event will probably occur in most circumstances (i.e., less than 0.5 year)

Calculate the Gross Risk Rating

- Gross Risk Rating is a function of the risk impact and risk likelihood. After assigning values to risk impact and risk likelihood, the following formula shall be used to arrive at Gross Risk Value.

Gross Risk Rating = Risk Impact * Risk Likelihood

- Below table describes the possible gross risk rating values.

		Risk Likelihood		
		Unlikely	Possible	Likely
B u s i n e s s i m p a c t	Major	3 (Low Risk)	6 (High Risk)	9 (High Risk)
	Moderate	2 (Low Risk)	4 (Medium Risk)	6 (High Risk)
	Insignificant	1 (Low Risk)	2 (Low Risk)	3 (Low Risk)

- High and medium risks shall be managed after evaluating the existing controls and using appropriate risk treatment techniques.

Residual Risk

- The Residual Risk value will be calculated before considering the risk treatment option. The effectiveness of current controls will be considered when calculating the Residual risk as per below criteria.

	☰ Status	☰ Control Description
1	Weak/ No Controls	Controls do not exist or else are not operating effectively. Risk will not be controlled.
2	Needs improvement	Basic risk management systems, process controls and procedures in place. No guaranteed risk will be controlled.
3	Effective	Risk management systems, process controls and procedures in place and can be relied upon to mitigate or detect risk materializing in most circumstances.

- Impact and likelihood of the risk shall be re-evaluated after considering the controls in place.
- The Residual Risk value will be calculated using the same formula.

Residual Risk Level = Risk Impact (after considering the controls in place) * Risk Likelihood (after considering the controls in place).

- The risk matrix can be used to evaluate the residual risks.

		Risk Likelihood		
		Unlikely	Possible	Likely
Business Impact	Major	3 (Low Risk)	6 (High Risk)	9 (High Risk)
	Moderate	2 (Low Risk)	4 (Medium Risk)	6 (High Risk)
	Insignificant	1 (Low Risk)	2 (Low Risk)	3 (Low Risk)

- The following tables detail how the risks shall be treated when the risk values fall within the defined ranges.

Residual Risk Treatment based on the risk value

	≡ Risk Measure	≡ Risk Treatment Required
1	1-3 Low Risk	Risk is acceptable. No further action required.

2	4 Medium Risk	Medium Priority – Risk Treatment is required. Implement controls within a time duration of 1 month. Such risks could be accepted if approved by the ISSC.
3	6-9 High risk	High Priority – Risk Treatment is required. Implement controls at an immediate timeline to mitigate risks. Such risks could be accepted if approved by the ISC.

- Residual risk will be re-calculated after the completion of risk treatment actions.

Risk Treatment

- Taking into consideration risk impact and risk likelihood, risk treatment procedures shall be identified and implemented.
- A formal risk treatment plan should be prepared. The risk treatment could be any of the following:
 - Avoiding the risk.
 - Implementation of additional controls to reduce the impact of risk – Controls can be selected from ISO/IEC 27001:2022Annexure A.
 - Transfer of risk – outsourcing, insurance, etc.; and
 - Risk acceptance – in line with the risk acceptance criteria stated in this risk assessment procedure.
- The existing and planned controls will be mapped to the ISO/IEC 27001:2022Annexure – A controls.

Risk Owner Identification

- For each risk identified, the risk owner shall be identified by Bistec.
- A risk owner shall be authorized personnel who has the authority to execute risk treatment plan and take decision over the risk identified.
- Risk owners are responsible for monitoring their risks and executing the risk treatment plan as appropriate.

Risk Acceptance Criteria

- The information security risk acceptance shall be based on the following criteria's:
 - The cost of controls is significantly higher than the possible benefits gained from implementing such controls.
 - Acceptance of risk does not violate any legal or statutory requirements.
 - Regional, socioeconomic, and environmental aspects that prevent the implementation of controls; and
 - The possible adverse impacts on business operations due to implementation of the controls and the related stakeholders' concerns and priorities.
- Risks could be accepted if accepting such risks does not impact Bistec 's ability to effectively operate the information security management system.
- Risks will be accepted until the risk treatment actions are completed.

Communication of Risk Acceptance

- An internal e-mail should be prepared by the risk owner for accepting risks. The e-mail shall include the following:
 - Processes/ Information assets that support or involved in consideration.
 - Description of the risk.
 - Justification for the risk acceptance.
 - Criteria for risk acceptance as per this methodology; and
 - Any plans to reduce the risk in future (if any).

- The e-mail should be addressed to ISC by the risk owner and copied to the IS Officer. ISC shall validate the risk acceptance by reviewing the documented justification is in line with the risk acceptance criteria as given in the risk assessment methodology. A member of ISC, on behalf of the ISC, shall approve the e-mail accepting the risk.
- Further for accepting risk all the above topics can also be discussed during ISC meetings and decisions can be taken at the meeting.

Review and Approval

- Once the risk assessment exercise is completed, the risk assessment, risk treatment plans and residual risks shall be reviewed by the ISC. The risk Assessment shall be updated by risk owners based on input provided by the ISC.

Execution of procedure

The IS officer shall be responsible for implementing this procedure and evaluating the information security risk assessments and management activities. The IS officer shall coordinate with respective business units within Bistec to perform the risk assessment, monitor and oversee the risk assessment management activities.